

Ataque de Confinamento em Subgrupos e Reconstrução CRT contra Diffie-Hellman



[Uma análise matemática e de rede sobre a exploração
de cofatores suaves e falhas de validação]

Baseado no Desafio 57 e Artigo NDSS 2016-995

A Anatomia do Alvo: Primos Seguros vs. Parâmetros DSA

Primos Seguros (Safe Primes)

$$p = 2q + 1$$

q é um primo de Sophie Germain

- O grupo multiplicativo tem ordem $p-1$.
- O subgrupo gerado tem tamanho máximo.
- Imune a ataques de pequenos subgrupos, porém a exponenciação é computacionalmente pesada.

p

q

Grupos DSA (RFC 5114)

$$p - 1 = q \cdot j$$

j é o cofator suave

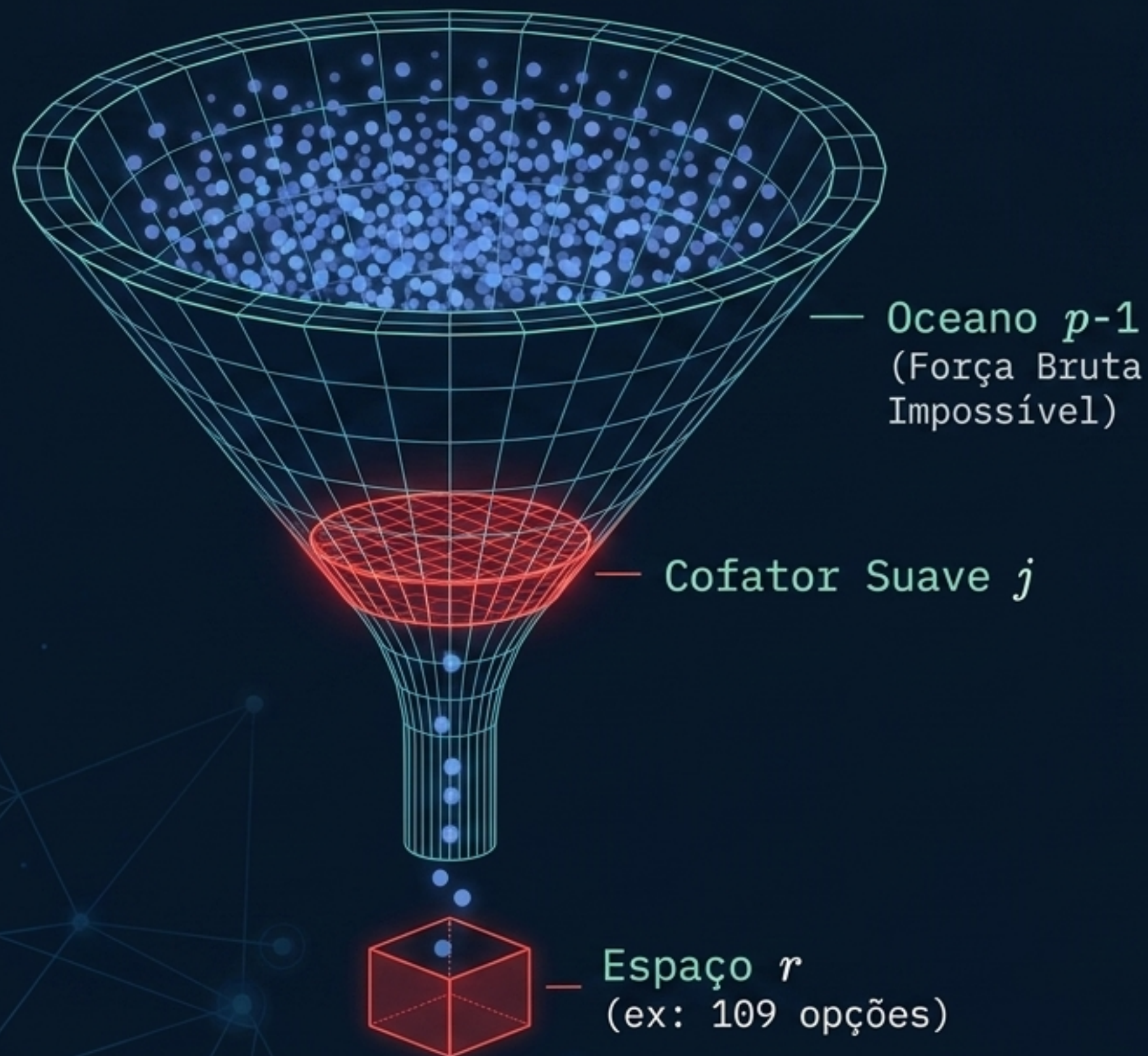
- O gerador g tem ordem q (ex: 256 bits) em vez de p (ex: 2048 bits).
- O cofator j pode ser composto por múltiplos fatores primos pequenos.
- Requer validação estrita. Falhas de implementação permitem o confinamento.

p

q

Cofator j (Espaço Vulnerável)

0 Vetor de Ataque: A Metáfora do Confinamento



1 A Falha na Planta

Sabemos que $j = \frac{(p-1)}{q}q$. Se j possuir pequenos fatores primos (ex: $r = 2, 3, 5, 109\dots$), a estrutura modular torna-se explorável.

2 A Injeção do Atacante

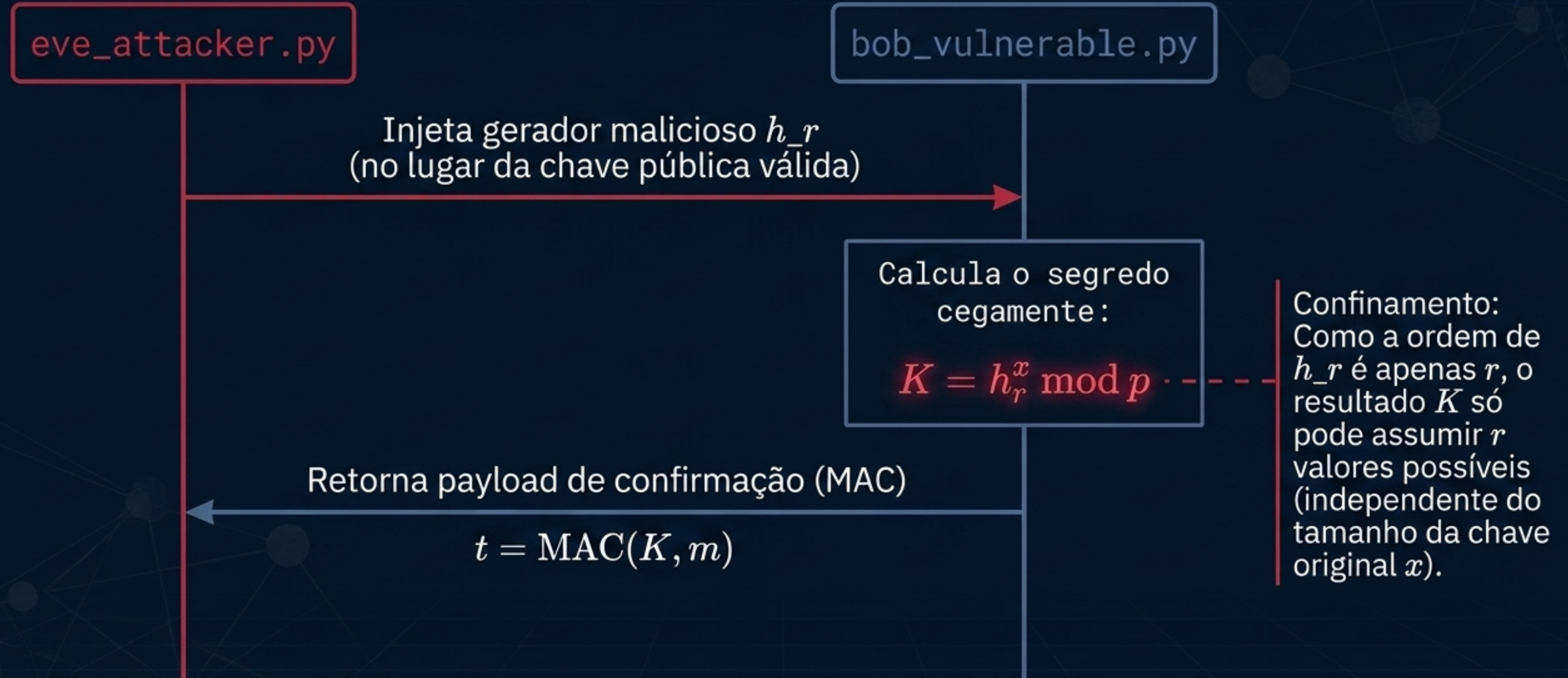
O atacante forja um gerador malicioso h com ordem r exata:

$$h = rand^{(p-1)/r} \bmod p$$

3 0 Confinamento

Se a vítima aceitar h sem validar a ordem do grupo, o segredo derivado K cairá em um subgrupo minúsculo de tamanho r . A busca pelo segredo torna-se trivial.

O Handshake Envenenado



Extração Bruta Offline (Método de Pohlig-Hellman)

```
Ciberseguranca_Eve_Bob_Alice_Jose> python3 eve_attacker.py
```

```
[*] Fatores primos encontrados (< 2^16):
```

```
[2, 3, 5, 109, 7963, 8539, 20641, 38833, 39341...]
```

```
--- Geradores h ---
```

```
Para r = 2: h = 719977399739... (h^2 mod p) = 1
```

```
Para r = 3: h = 300796331761... (h^3 mod p) = 1
```

```
Para r = 5: h = 157572304918... (h^5 mod p) = 1
```

```
Para r = 109: h = 4066404269... (h^109 mod p) = 1
```

O Loop de Força Bruta

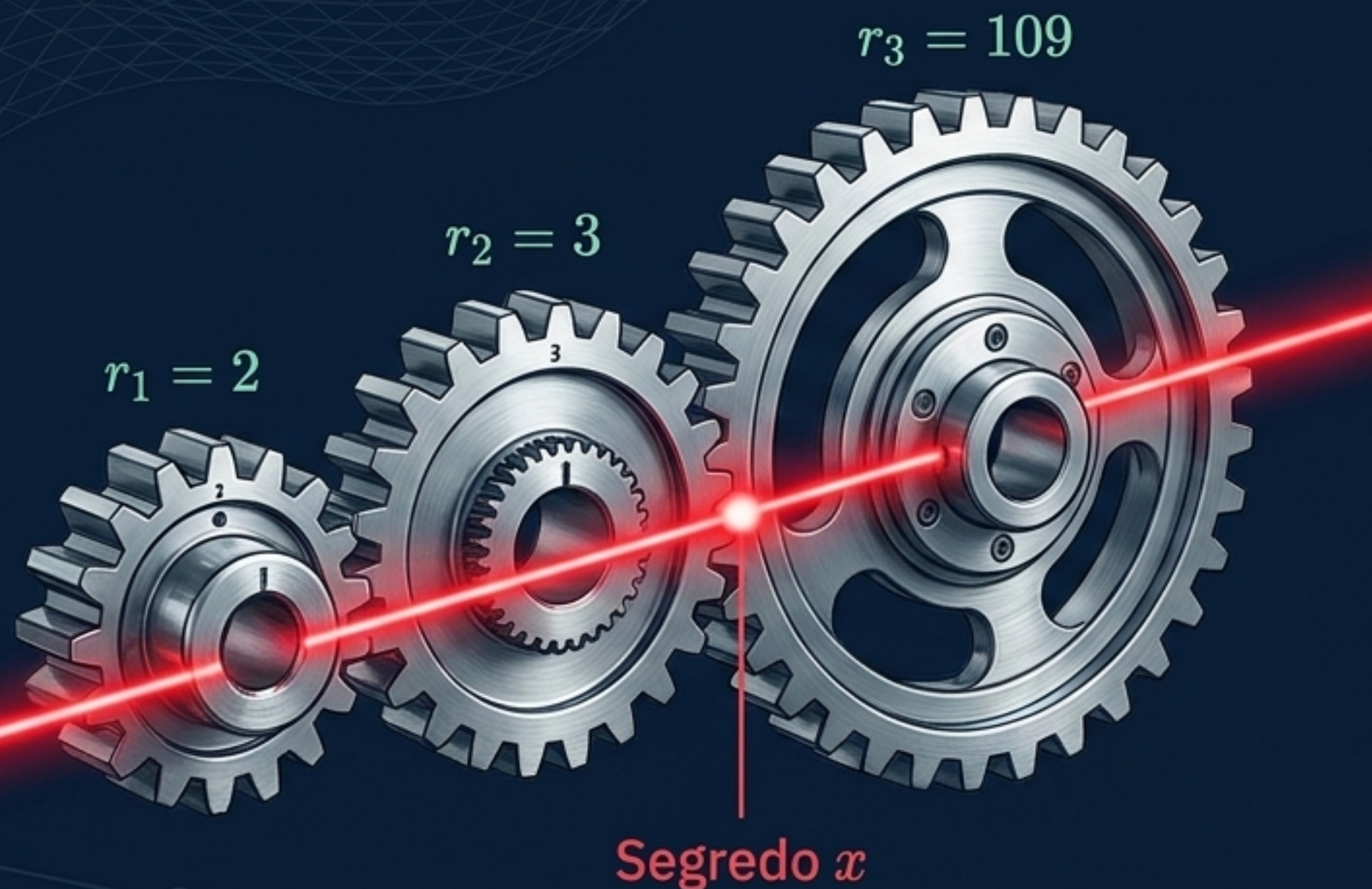
- Eve já capturou a mensagem m e a assinatura t .
- Não há mais necessidade de interagir com a vítima na rede.
- Eve itera uma variável i de 1 até r (ex: apenas 109 tentativas locais).
- Teste condicional:

Se $\text{MAC}(h^i \bmod p, m) == t$

- Sucesso: Eve descobriu o resíduo exato da chave privada:

$$x \equiv i \bmod r$$

A Montagem do Quebra-Cabeça Modular (CRT)



A Metáfora das Engrenagens

O Sistema de Congruências Coletado:

$$x \equiv b_1 \pmod{r_1}$$

$$x \equiv b_2 \pmod{r_2}$$

$$x \equiv b_3 \pmod{r_3}$$

$\vdots$

Teorema Chinês do Resto (CRT)

Quando $\prod r_i > q$, o segredo x é reconstruído de forma inequívoca dentro do espaço de busca original q .

Algoritmo de Euclides Estendido

Utilizado computacionalmente para encontrar os inversos modulares necessários que combinam os resíduos parciais em uma única chave mestre.

Arquitetura do Laboratório de Simulação



Tema	Ataque de confinamento em subgrupos pequenos contra DH e reconstrução por CRT
Dificuldade	Difícil
Por que escolher	Apresenta diretamente a validação de subgrupos em DH finito, o ataque de confinamento e a reconstrução do segredo por CRT.
Materiais públicos	https://www.allonob.com/challenge
Artefatos e reprodução	https://www.github.com/content/contonin7-artefstos-campoortre-anbcentar
Escopo e cuidados	Escopo e cuidados: oia, e nígies exóicopo e curidades.
Sugestão de abordagem	Sugestão de abordagem em implementação de oráculo, atacante e defesas em repositório.

Especificação autocontida com implementação de oráculo, atacante e defesas em repositório público.

O Erro (Código Ingênuo)

```
K = pow(Y_received, x, p)
```



Nenhuma verificação de integridade do grupo sobre o payload. Confiança implícita na rede, permitindo injeção de h_r .

A Defesa (Higiene Criptográfica)

1. Limites Estritos:

$$1 < Y_{received} < p - 1$$

Evita pequenos subgrupos triviais de ordem 2)

2. Validação de Subgrupo:

$$Y_{received}^q \bmod p \equiv 1$$

Garante que o elemento fornecido opera DENTRO da ordem q segura)

3. Cofactor Clearing: Substituir o cálculo padrão por:

$$K = Y^{j \cdot x} \bmod p$$

Anula completamente a influência maliciosa que reside no subgrupo pequeno, pois $h^j \equiv 1$)

4. Chaves Efêmeras:

Gerar um novo x por conexão para garantir Perfect Forward Secrecy)

Veredito do Teste: Ataque vs. Defesa

Terminal 2: Teste Porta 8081

 **CHECK**

```
[EVE] Conectando a bob_secure.py:8081...  
[EVE] Injetando gerador malicioso h (ordem 109)...  
[BOB_SECURE] FATAL: Validação de Subgrupo falhou. ( $Y_q^q \bmod p \neq 1$ ).  
[BOB_SECURE] Conexão encerrada pelo peer. Abortando.
```

Terminal 1: Teste Porta 8080

WARNING

```
[EVE] Conectando a bob_vulnerable.py:8080...  
[EVE] Injetando gerador malicioso h (ordem 109)...  
[BOB_VULN] Handshake concluído. MAC de confirmação retornado.  
[EVE] Resíduo extraído via força bruta com sucesso:  $x \equiv 42 \bmod 109$ .
```


Do Laboratório para a Internet: Impacto em Escala

O Risco do RFC 5114

Parâmetros normalizados, como o Group 23 (primo de 2048 bits), permitiram a recuperação total de chave privada com apenas 2^{33} trabalho online e 2^{47} trabalho offline.

O Caso Amazon ELB

O Amazon Elastic Load Balancer reutilizava chaves estáticas. Vulnerável a ataques de confinamento, permitindo a extração parcial da chave mestre em produção.

A Falha na Prática (2016)

Milhões de hosts ativos (HTTPS, IKEv1/v2, SSH) utilizavam primos não seguros, sem a devida validação da ordem do subgrupo por padrão.

A Correção Global

A OpenSSL foi forçada a aplicar checks de validação de subgrupo estritos por padrão na biblioteca base, e a abolir completamente a reutilização de chaves estáticas.

CVE-2016-0701